Matrice d’applicabilité ReCyF / NIS2

Olivier HIMBLOT • ÉnergieAlp • 15 octobre 2026 • Version 3 documentaire — cadrage ReCyF

Référentiel principal corrigé : ReCyF v2.5 du 17/03/2026, document de travail. La correspondance juridique NIS2 est conservée ; le contrôle est désormais structuré par objectifs et MAC du ReCyF.

Compétence : Participer à l’élaboration et à la mise en œuvre de la politique de sécurité.

Critère : produire une matrice d’applicabilité NIS2 article par article, reliant les obligations aux configurations techniques, et tenir un registre des actifs critiques et des procédures de gestion des sous-traitants.

Élément évalué	Pièce présentée	Portée de la preuve
Applicabilité ReCyF puis correspondance juridique	Vingt objectifs, MAC sélectionnés et articles NIS2 1 à 46	Raisonnement documentaire, exclusions et réserves explicites
Lien obligation / configuration	Contrôles CT-01 à CT-16 : cible, test et preuve attendue	Conception proposée ; aucune configuration réelle exportée
Actifs critiques	Registre EA-01 à EA-05 et justification C/I/D/T	V0 du scénario ; inventaire existant non fourni, validation métier attendue
Sous-traitants	Registre ST-01 à ST-03 ; procédures PR-ST-01 à PR-ST-04	Procédures rédigées pour l’exercice ; application non attestée

Périmètre : entreprise fictive de distribution d’électricité, environ 650 salariés, 280 000 clients, 30 M€ de chiffre d’affaires 2025. Systèmes : SCADA, compteurs communicants, CRM/facturation, analytics et VPN. Le SCADA est traité comme un actif, sans étude technique industrielle.

Établi dans le scénario : VPN sans MFA, cloud sans contrat ni analyse de risque formalisée, registre incomplet et accès prestataires sans revue périodique documentée. Non établi : conformité réelle, résultat de simulateur, statut OIV, journaux complets, sauvegardes ou contrôles effectivement exécutés.

Lecture : A = retenu dans l’hypothèse EE ; C = conditionnel, à confirmer ; H = cadre institutionnel ou juridique sans configuration directement déductible ; X = hors activité décrite. Ces codes qualifient l’applicabilité, jamais le niveau de conformité.

1. Qualification et règles de décision

Point	Fait / raisonnement	Décision et réserve
Activité — annexe I	Gestionnaire de réseau de distribution d’électricité : type d’entité du secteur énergie.	Retenu dans le champ sectoriel.
Taille — art. 2 et 3	Environ 650 salariés : dépassement du plafond d’effectif des moyennes entreprises ; 30 M€ de CA n’exclut pas ce constat.	EE proposée selon art. 3 §1 a ; confirmer effectif de référence, périmètre juridique et groupe.
Qualification	Le dossier laisse volontairement la qualification ouverte. Aucun simulateur n’a été exécuté.	Conclusion documentaire proposée, sans désignation officielle. OIV à déterminer séparément.
Directive / droit français	La directive sert de source européenne. La page ANSSI présente ReCyF comme support de préparation ; ce document ne reconstitue pas la transposition française.	Vérifier textes nationaux publiés, calendrier, autorité et canaux avant usage opérationnel. Aucun numéro de loi française inventé.
Responsabilités connues	DSI : CRM, VPN, analytics. Responsable Production : supervision. RSSI : seul habilité à valider une dérogation de sécurité.	Les autres rôles et délais proposés ci-après doivent être approuvés. Une dérogation ne supprime pas une obligation légale.
Disponibilité	Supervision et SI clientèle disponibles en continu ; changements en fenêtres validées, nuit/hors pics sauf urgence avérée.	Avant changement : essai, critères de réussite, retour arrière et validation Production/DSI selon périmètre.

Méthode : fait du dossier → article et condition d’application → objectif de sécurité → configuration cible proposée → test → preuve → décision et responsable. Une absence dans le dossier signifie « non documenté », sauf lorsque le dossier affirme expressément un écart.

Les propositions techniques ne sont pas des prescriptions littérales de la directive. Elles traduisent ses objectifs dans le périmètre ÉnergieAlp ; paramètres, produits, versions, durées de conservation et tolérances doivent être décidés après analyse des risques.

Référentiel principal R : ReCyF v2.5 (source et matrice ci-après). Sources juridiques et scénario : S1 = directive UE 2022/2555 du 14 décembre 2022 ; S2 = dossier pédagogique ÉnergieAlp, §1 à §6 ; S3 = fiches du mémo, itérations 1 et 2 ; S4 = orientation ANSSI NIS2. Références et chemins détaillés en dernière page.

ReCyF — base de l’exercice et conditions d’application

ReCyF v2.5 du 17/03/2026 — document de travail. Source officielle : https://messervices.cyber.gouv.fr/documents-ressources/20260317_NIS_V2_ReCyF_v2.5.pdf

Correction du cadrage à la demande du formateur : les objectifs et moyens acceptables de conformité (MAC) du ReCyF structurent désormais la matrice. Les articles NIS2 servent de correspondance juridique. ReCyF est utilisé comme référentiel imposé pour cet exercice, sans lui attribuer le statut d’un texte national adopté.

Hypothèse EE documentaire conservée : objectifs 1 à 20 examinés. Objectifs 16 à 20 propres aux EE ; certains MAC des objectifs 1 à 15 le sont également. Conserver suffixes et colonnes EI/EE du document officiel ; ne pas déduire l’application d’un MAC uniquement du titre de son objectif.

La matrice couvre les vingt objectifs avec une sélection de MAC pertinents ; elle ne prétend pas être un audit unitaire exhaustif de chaque MAC sur chaque SI. Une ligne identifie le périmètre, le contrôle proposé, le constat et la preuve attendue ; les moyens non détaillés restent à examiner par SI.

Notion	Conséquence dans le travail
Objectif / MAC	L’objectif décrit le résultat recherché ; le MAC est un moyen proposé. Une alternative est motivée dans l’analyse selon 2.C.3-EI/EE ; aucune exemption ou acceptation ANSSI automatique.
Périmètre — 1.1-EI/EE et 1.2-EI/EE	Recenser toutes les activités, services et SI, au-delà des cinq actifs critiques. Pas d’exclusion proposée ; toute exclusion doit être justifiée selon risques, sans argumenter seulement par une protection déjà installée.
Preuves et état	P-DOS-01 atteste uniquement les faits du scénario. Registre/matrice/politique sont des productions documentaires ; les contrôles techniques, contrats et décisions approuvées restent à prouver.
Cloud Act / SecNumCloud	Analyse juridique et qualification d’une offre éclairent le choix fournisseur ; ni le mot souverain ni SecNumCloud ne démontrent automatiquement la conformité du SI client au ReCyF.

Références : texte officiel pp. 3 et 7–38 ; tables de correspondance NIS2 pp. 44–47. Les formulations ci-après sont des synthèses locales. Pages indiquées selon pagination du PDF officiel, consultation du 15/10/2026.

Matrice ReCyF — objectifs 1 à 4

Applicabilité : retenu dans l’hypothèse EE sur les SI concernés ; exclusions non justifiées ici. J = approbation future du plan. Chaque R est un objectif ; les MAC sélectionnés précisent les contrôles, sans déclaration de conformité.

Objectif / source	MAC sélectionnés	Périmètre et cible proposée	Preuve / état / écart	Action / pilote
R-01 Recensement des SI p. 7 NIS2 art. 21 §2 i	1.1-EI/EE ; 1.2-EI/EE ; 1.3-EI/EE	Toutes activités, services et SI, pas seulement les cinq actifs critiques Relier activités/services à un responsable et aux SI ; justifier toute exclusion par les risques ; valider et revoir au moins annuellement et après évolution.	Registre incomplet déclaré ; V0 cinq actifs produite, liste des activités et SI support à compléter. Preuve : liste validée et exclusions motivées.	DSI/Production : rapprochement J+30 ; conserver les cinq EA sans les assimiler à tout le périmètre.
R-02 Gouvernance de la sécurité p. 8–10 NIS2 art. 20 ; 21 §2 a/f/h/i	2.A.1-EI/EE ; 2.A.2-EE ; 2.B.1-EI/EE ; 2.B.3-EI/EE ; 2.C.1-EI/EE ; 2.C.2-EI/EE ; 2.C.3-EI/EE	Direction, RSSI et tous SI PSSI approuvée ; point de contact ; analyse de conformité par SI et action avec responsable/échéance ; justifier une mesure alternative au lieu de déclarer une exemption.	PSSI et matrice rédigées ici ; adoption et application non prouvées. Preuve : approbation, analyse par SI et suivi.	Direction/RSSI : revue J+30 ; décision, diffusion et preuves à recueillir.
R-03 Écosystème et fournisseurs p. 11 NIS2 art. 21 §2 d/i	3.A.1-EI/EE ; 3.A.2-EI/EE ; 3.B.1-EI/EE ; 3.B.2-EI/EE	GridSoft, CloudPeak, RéseauTech et interconnexions Cartographier prestation, interconnexions et contact ; obtenir garanties contractuelles et vérifier périodiquement le service.	Contrat CloudPeak absent ; garanties et contacts non fournis. Preuve : cartographie, contrat, revue/audit fournisseur.	DSI/Production, RSSI/juridique proposés : lancement J+7 ; PR-ST-01/02.
R-04 Sécurité et ressources humaines p. 12 NIS2 art. 21 §2 g	4.1-EI/EE ; 4.2-EI/EE ; 4.3-EE ; 4.4-EI/EE ; 4.5-EI/EE	Personnels et tiers, de l’arrivée au départ Charte, sensibilisation continue, clauses pertinentes et formation selon rôles ; gérer droits et restitution lors des mouvements.	Non documenté. Preuve : charte, formation, dossiers arrivée/mobilité/départ anonymisés.	RSSI/RH et DSI proposés : vérifier existant J+30, planifier formation.

Matrice ReCyF — objectifs 5 à 8

Applicabilité : retenu dans l’hypothèse EE sur les SI concernés ; exclusions non justifiées ici. J = approbation future du plan. Chaque R est un objectif ; les MAC sélectionnés précisent les contrôles, sans déclaration de conformité.

Objectif / source	MAC sélectionnés	Périmètre et cible proposée	Preuve / état / écart	Action / pilote
R-05 Cartographie et maintien des SI p. 13–14 NIS2 art. 21 §2 e/i	5.A.1-EI/EE ; 5.B.1-EE ; 5.B.3-EI/EE ; 5.B.4-EI/EE ; 5.B.5-EE ; 5.B.7-EI/EE ; 5.B.9-EI/EE	Tous EA, logiciels et matériels confirmés Cartographie exploitable en incident ; veille, correctifs et versions supportées ; tester puis appliquer sans retard injustifié selon les MAC ; atténuer les impossibilités.	Versions/support non fournis ; inventaire incomplet déclaré. Preuve : versions, avis, essais et changements.	DSI/Production : inventaire J+30, correction planifiée selon risque et fenêtres.
R-06 Accès physiques p. 15 NIS2 art. 21 §2	6.1-EI/EE ; 6.2-EE ; 6.3-EE ; 6.4-EI/EE	Locaux, salles et équipements concernés Limiter droits au besoin ; autoriser/accompagner visiteurs ; protection permettant prévention, surveillance et réaction aux accès indus.	Non documenté ; absence non démontrée. Preuve : zones, habilitations et contrôle d’un accès autorisé/refusé.	Production/DSI, rôles à confirmer : revue J+30 sans intrusion non autorisée.
R-07 Architecture des SI p. 16–17 NIS2 art. 21 §2 e/h	7.A.1-EI/EE ; 7.A.3-EE ; 7.A.4-EE ; 7.B.1-EI/EE ; 7.B.3-EI/EE ; 7.B.5-EI/EE	EA-01 à EA-05, sous-systèmes et frontières cloud Cloisonner SI/sous-systèmes, documenter flux nécessaires, bloquer les autres par défaut et revoir techniquement le filtrage annuellement.	Topologie/règles inconnues. Preuve : cartographie, matrice de flux, règles chargées et tests autorisé/refusé.	DSI/Production : étudier flux avant pilote/migration ; accès SCADA sans approfondissement industriel.
R-08 Accès distants p. 18 NIS2 art. 21 §2 e/h/j	8.1-EI/EE ; 8.2-EI/EE ; 8.3-EE ; 8.4-EE ; 8.5-EE	VPN EA-05 et terminaux distants autorisés Chiffrer l’accès ; en EE, MFA comportant au moins un facteur de connaissance ; chiffrer les supports des postes distants ; impossibilité MFA à traiter selon 8.4-EE.	VPN sans MFA déclaré ; chiffrement/terminaux non évalués. Preuve : paramètres, test du facteur de connaissance et second facteur, refus et secours.	DSI avec Production/RSSI : étude J+7 ; fenêtre après essai, exception motivée et compensée.

Matrice ReCyF — objectifs 9 à 12

Applicabilité : retenu dans l’hypothèse EE sur les SI concernés ; exclusions non justifiées ici. J = approbation future du plan. Chaque R est un objectif ; les MAC sélectionnés précisent les contrôles, sans déclaration de conformité.

Objectif / source	MAC sélectionnés	Périmètre et cible proposée	Preuve / état / écart	Action / pilote
R-09 Protection contre les codes malveillants p. 19 NIS2 art. 21 §2 e	9.1-EI/EE ; 9.2-EE ; 9.4-EE ; 9.5-EI/EE ; 9.6-EI/EE ; 9.7-EI/EE	Terminaux, serveurs, supports et données entrantes En EE, ressources gérées par entité/prestataire mandaté ; empêcher autres connexions ; limiter supports et analyser les entrées selon MAC.	Non documenté ; ni antivirus ni BYOD autorisé présumés. Preuve : parc autorisé, protection active et test d’entrée contrôlé.	DSI/Production : vérifier compatibilité des ressources et planifier contrôle J+30.
R-10 Identités et droits utilisateurs p. 20–21 NIS2 art. 21 §2 e/i/j	10.A.1-EI/EE ; 10.A.5-EI/EE ; 10.A.6-EI/EE ; 10.B.2-EI/EE ; 10.C.2-EI/EE ; 10.C.4-EI/EE	Comptes internes, processus et prestataires Comptes individuels, secrets par défaut changés, retrait des comptes inutiles ; moindre privilège ; revues comptes/droits au moins annuelles.	Revues tiers non documentées déclarées. Preuve : droits, approbations, revue et refus après retrait.	DSI/Production : première revue J+15 ; trimestre proposé localement, plus fréquent que minimum annuel.
R-11 Administration des SI p. 22–23 NIS2 art. 21 §2 e/i	11.A.1-EI/EE ; 11.A.2-EI/EE ; 11.A.6-EE ; 11.A.7-EE ; 11.B.1-EI/EE	Administration interne et prestataires Comptes dédiés et autorisés, liste des administrateurs, contrôle des droits lors des changements ; maintenir la sécurité des annuaires.	Non documenté. Preuve : liste/comptes dédiés, habilitations et contrôle de séparation des usages.	DSI/Production : vérifier existant J+30 et prévoir retrait des comptes non justifiés.
R-12 Identification et réaction aux incidents p. 24–25 NIS2 art. 21 §2 b	12.1-EE ; 12.2-EE ; 12.3-EI/EE ; 12.4-EE ; 12.5-EE ; 12.7-EE	Tous EA et signalements des tiers/clients Collecter signalements, qualifier et réagir ; procédure, analyse des causes après incident et protection des relevés.	Non documenté ; journal VPN mentionné ne démontre pas gestion d’incident. Preuve : événement, ticket, procédure et REX.	RSSI/DSI/Production : vérifier existant J+30 et exercice, sans notification externe simulée comme réelle.

Matrice ReCyF — objectifs 13 à 16

Applicabilité : retenu dans l’hypothèse EE sur les SI concernés ; exclusions non justifiées ici. J = approbation future du plan. Chaque R est un objectif ; les MAC sélectionnés précisent les contrôles, sans déclaration de conformité.

Objectif / source	MAC sélectionnés	Périmètre et cible proposée	Preuve / état / écart	Action / pilote
R-13 Continuité et reprise p. 26 NIS2 art. 21 §2 c	13.1-EI/EE ; 13.2-EI/EE ; 13.3-EI/EE ; 13.4-EE ; 13.5-EI/EE ; 13.6-EE	EA-01/03 prioritaires, ensemble des activités Sauvegarder, protéger copies et tester restauration au moins annuellement ; définir DMIA et PRD par activité/service ; PCA/PRA cohérents.	Continuité requise par scénario ; moyens non documentés. Preuve : objectifs métiers, restauration mesurée et plans.	DSI/Production et métiers : objectifs avant migration ; test semestriel proposé localement.
R-14 Crise cyber p. 27–28 NIS2 art. 21 §2 c/j	14.1-EI/EE ; 14.2-EI/EE ; 14.3-EI/EE ; 14.4-EI/EE ; 14.6-EE ; 14.8-EE ; 14.10-EE	Entité, cloud et prestataires Procédure et critères d’activation ; annuaires utilisables SI indisponible, dont liste imprimée ; isolement/reconstruction et communication de secours.	Non documenté. Preuve : procédure, annuaires protégés, exercice de mobilisation et sortie de crise.	RSSI/direction et tiers : prévoir crise CloudPeak et contacts avant migration.
R-15 Exercices et entraînements p. 29 NIS2 art. 21 §2 b/c/g	15.1-EI/EE ; 15.2-EE ; 15.3-EE ; 15.4-EE	Incidents, continuité et crise Exercice sur table ; en EE stratégie et programme triennal avec acteurs, scénarios, objectifs et évaluation.	Aucun exercice attesté ; débrief non réalisé sur preuves. Preuve : programme, rapports et actions.	RSSI et métiers : planifier après revue J+30 ; résultats à recueillir.
R-16 Approche par les risques p. 30–31 NIS2 art. 21 §2 a	16.1-EE ; 16.2-EE ; 16.3-EE ; 16.4-EE	Chaque activité/service et SI ; CRM/analytics Analyser risque par activité et SI supports, décider traitements et accepter risques résiduels ; réexaminer au moins tous les trois ans et après évolution/incident.	Analyse cloud absente ; RC-01 à RC-05 préparatoires, probabilités non établies. Preuve : analyse validée et décisions résiduelles.	Direction et responsables métier avec RSSI : lancement J+7, orientation J+30.

Matrice ReCyF — objectifs 17 à 20

Applicabilité : retenu dans l’hypothèse EE sur les SI concernés ; exclusions non justifiées ici. J = approbation future du plan. Chaque R est un objectif ; les MAC sélectionnés précisent les contrôles, sans déclaration de conformité.

Objectif / source	MAC sélectionnés	Périmètre et cible proposée	Preuve / état / écart	Action / pilote
R-17 Audit de sécurité p. 32–33 NIS2 art. 21 §2 f	17.1-EE ; 17.2-EE ; 17.3-EE ; 17.4-EE ; 17.5-EE	SI selon criticité et exposition Programme d’audit proportionné ; couvrir organisation/physique, architecture, configuration et intrusion selon périmètre ; rapport et actions.	Aucun audit réel attesté. Preuve : programme, mandat, rapport et recontrôle.	RSSI/direction : planifier après analyse ; aucun scan de production non autorisé.
R-18 Configuration des ressources p. 34 NIS2 art. 21 §2 e	18.1-EE ; 18.2-EE ; 18.3-EE ; 18.4-EE	Ressources de tous EA, y compris cibles cloud Limiter logiciels/services nécessaires, durcir selon recommandations, compenser impossibilités et revoir configurations.	Non documenté. Preuve : configuration effective, référence de durcissement et contrôle des écarts.	DSI/Production : baseline et test avant pilote ; revue selon risque.
R-19 Ressources dédiées à l’administration p. 35–36 NIS2 art. 21 §2 e	19.1-EE ; 19.4-EE ; 19.6-EE ; 19.7-EE ; 19.9-EE ; 19.10-EE ; 19.11-EE	Postes, réseaux et flux d’administration des EA Administration sur réseau/poste dédiés ; liaisons dédiées et protocoles protégés ; alternatives prévues aux MAC si impossibilité justifiée, sans exemption générale.	Non documenté. Preuve : schéma et tests d’isolement, poste et protocoles d’administration.	DSI/Production : concevoir chemin d’administration avant bascule, avec fournisseur.
R-20 Supervision de sécurité p. 37–38 NIS2 art. 21 §2 b	20.1-EE ; 20.2-EE ; 20.3-EE ; 20.4-EE ; 20.5-EE ; 20.6-EE	Journaux/événements utiles et SI de supervision Dimensionner collecte/traitement et scénarios, conserver au moins trois mois sans préjudice des autres obligations, protéger les données et améliorer la couverture.	Couverture/traitement inconnus. Preuve : sources, événement retracé, délai mesuré, rétention et protection.	DSI/RSSI : cible prudente de prise en compte sous 24 h ; divergence de rédaction objectif/MAC signalée ci-dessous.

ReCyF — conditions précises à reprendre dans les tests

Mesure(s)	Critère de contrôle et limite
8.3-EE ; 8.4-EE	MFA distant comportant au moins un facteur de connaissance : vérifier ce facteur et le second facteur dans les essais. Si impossibilité technique/opérationnelle, justifier et réduire le risque selon 8.4-EE ; une simple autorisation interne ne vaut pas conformité.
1.3-EI/EE ; 7.B.5-EI/EE ; 10.A.6-EI/EE ; 10.C.4-EI/EE	Revues au moins annuelles selon leur objet : liste activités/SI, filtrage, comptes et droits. Les rythmes trimestriels de la politique sont des choix locaux plus fréquents, pas une citation du ReCyF.
13.2-EI/EE ; 13.4-EE ; 13.6-EE	Restauration testée au moins annuellement ; DMIA et PRD par activité/service en EE ; PCA/PRA cohérents. Les D3/D4 du registre ne sont pas des objectifs de reprise déjà validés. Semestriel = proposition locale.
15.4-EE ; 16.4-EE	Programme triennal d’entraînement ; analyse des risques revue au minimum tous les trois ans et selon événements. Prévoir les scénarios cloud, incident et reprise.
20.1-EE ; 20.5-EE ; 20.6-EE	MAC 20.1 : rédaction « 24h ouvrés », alors que l’objectif mentionne 24 heures. Différence tracée ; cible locale prudente proposée : maximum 24 h calendaires, sans interprétation officielle revendiquée. Conserver événements/supervision au moins trois mois et les protéger, en respectant les autres obligations.
2.C.1-EI/EE ; 2.C.2-EI/EE ; 3.B.2-EI/EE	Analyse de conformité par SI, plan avec responsables/échéances et contrôle périodique des prestataires. Relier les actions existantes aux R/MAC ; ne pas clôturer sans preuve de vérification.

Notifications : les délais européens d’alerte et notification restent ceux de l’article 23 de NIS2, à articuler avec les règles nationales applicables ; le délai de prise en compte de supervision du ReCyF est un sujet distinct. Ne pas faire dire au ReCyF qu’il remplace le régime juridique de notification.

3. Gouvernance et cadre des configurations

ID / base	Exigence et applicabilité	Cible proposée / contrôle	Preuve et état	Pilote / action
CT-01 Art. 20 §1–2	Hypothèse EE : direction responsable de l’approbation et de la supervision des mesures ; formation.	Faire approuver PSSI, responsables, budget et tableau de suivi. Inclure formation de la direction et dispositif de formation des équipes. Contrôle : décisions et suivi des écarts.	PR-01 : PSSI signée, PV, suivi, attestations. Non documenté dans S2 ; aucune adoption démontrée.	Direction, coordination RSSI proposée. Vérifier l’existant et proposer validation à J+30.
CT-02 Art. 21 §1, §2 a	Hypothèse EE : analyse proportionnée des risques, tous risques, y compris environnement physique.	Relier chaque EA à impacts, menaces, dépendances, risque et traitement. Examiner énergie, locaux, télécoms et accès physiques. Contrôle : échantillon de risques reliés aux actifs.	PR-02 : analyse et décisions datées. Risque cloud non formalisé selon S2 ; autres analyses non documentées.	RSSI, DSI et Production. Prioriser cloud et accès supervision ; lancer à J+7.
CT-06b Art. 21 §3	Fournisseurs directs : tenir compte des vulnérabilités, qualité et pratiques de sécurité.	Évaluer GridSoft, CloudPeak et RéseauTech ; exiger preuves proportionnées, gestion des vulnérabilités et conditions d’accès. Contrôle : revue des trois dossiers.	PR-06 : évaluations, engagements et risques résiduels. Contrat CloudPeak absent dans S2 ; autres contrats non décrits.	DSI / Production, RSSI et juridique proposés ; PR-ST-01/02.
CT-16 Art. 21 §4	Corriger sans retard indu les non-conformités constatées aux mesures retenues.	Ouvrir un ticket par écart, responsable et cible ; tester correction, enregistrer preuve, arbitrer risques résiduels. Contrôle : empêcher clôture sans vérification.	PR-16 : registre d’écarts, tickets et recontrôles. Document préparé ; aucun ticket réel ni correction attestés.	RSSI pour suivi ; DSI/Production exécutants. Délais proposés en plan de remédiation.

Art. 21 §5 : suivre les actes d’exécution pertinents ; le règlement UE 2024/2690 cible certaines catégories de fournisseurs numériques. Le seul recours à CloudPeak n’établit pas son applicabilité directe à ÉnergieAlp. Les réglages détaillés retenus ci-après sont des propositions locales, à proportionner au risque.

J = date future d’approbation du plan. Les échéances ne sont pas des dates légales. Toute modification touchant supervision ou SI clientèle passe par une fenêtre validée, essais et retour arrière ; RSSI seul pour une dérogation de sécurité.

4. Matrice technique — article 21 §2, b à e

Chaque ligne est applicable dans l’hypothèse EE. Les cibles et tests sont proposés, sans exécution. Les constats reposent exclusivement sur S2 ; CT-02 couvre le point a.

ID / article	Périmètre	Configuration / dispositif cible	Test de contrôle attendu	Preuve / situation connue	Responsable proposé
CT-03 21 §2 b	Incidents — tous EA	Centraliser alertes et traces utiles avec source, compte, action, résultat et horodatage fiable ; définir triage et escalade.	Injecter un événement de test autorisé ; vérifier collecte, qualification et ticket sans prétendre simuler une attaque réelle.	PR-03 : événement brut, ticket, chronologie et revue. Journaux VPN mentionnés ; couverture/collecte non documentées.	RSSI / DSI, Production pour EA-01.
CT-04 21 §2 c	Continuité — EA-01/03 prioritaires	Définir objectifs de reprise et perte de données avec métiers ; sauvegardes séparées, accès limités et procédure de restauration ; solution de continuité adaptée à l’actif.	Restaurer un échantillon isolé ; contrôler données et service, mesurer délai et perte ; tester scénario de crise.	PR-04 : politique, test de restauration et décision métier. Sauvegardes et reprise non documentées.	DSI / Production. Aucune tolérance inventée comme validée.
CT-05 21 §2 c	Gestion de crise — tous EA	Définir cellule de crise, suppléants, annuaire protégé et accessible en cas de panne ; modes dégradés et règles de décision.	Exercice sur table : indisponibilité VPN ou cloud ; vérifier mobilisation, communication et décisions sans action sur production.	PR-05 : procédure et compte rendu d’exercice identifié comme simulé. Dispositif existant non documenté.	Direction, RSSI, DSI et Production ; rôles proposés.
CT-06 21 §2 d	Fournisseurs — ST-01/02/03	Comptes nominatifs de tiers, périmètre et durée approuvés, clauses incident/accès/réversibilité ; revue des responsabilités cloud.	Comparer comptes et contrats aux missions approuvées ; tester expiration et retrait sans interrompre la production.	PR-06 : contrats, habilitations, revues. Écarts déclarés : cloud sans contrat ; accès tiers sans revue documentée.	DSI / Production ; PR-ST-01 à 04.
CT-07 21 §2 e	Acquisition et maintenance — tous EA	Inventorier versions/support ; qualifier avis et correctifs ; paramètres de durcissement adaptés au produit ; canal de réception des vulnérabilités.	Sur environnement de test, appliquer un changement approuvé, vérifier service et retour arrière avant fenêtre de production.	PR-07 : inventaire versions, avis, tests et journal de changement. Versions, support et durcissement non fournis.	DSI / Production ; GridSoft consulté pour EA-01.

5. Matrice technique — article 21 §2, f à j

ID / article	Périmètre	Configuration / dispositif cible	Test de contrôle attendu	Preuve / situation connue	Responsable proposé
CT-08 21 §2 f	Tous EA	Planifier contrôles d’efficacité ; suivi des écarts et conservation protégée des résultats.	Échantillonner comptes, restaurations et correctifs ; rapprocher résultats des objectifs et décider actions.	PR-08 : plan, rapports et recontrôles. Aucun résultat fourni.	RSSI ; DSI / Production.
CT-09 21 §2 g	Personnel et tiers	Socle d’hygiène et formation selon rôles : comptes, accès distant, données et signalement ; suivi des habilitations.	Vérifier parcours d’accueil et évaluations ; exercice de signalement maîtrisé.	PR-09 : supports, présence et évaluation. Formation non documentée.	RSSI ; RH proposée.
CT-10 21 §2 h	EA-03/04/05 ; autres selon risque	Chiffrer flux et données sensibles selon analyse ; gérer certificats, accès aux clés, rotation et récupération ; paramètres à définir après inventaire.	Vérifier protocole/certificat réellement négocié et accès aux clés ; tester récupération sur copie isolée.	PR-10 : politique, export anonymisé, tests. Aucun protocole, algorithme ou clé observé.	DSI ; RSSI pour politique.
CT-11 21 §2 i	EA-01 à EA-05	Registre avec propriétaire, données, dépendances, criticité, version et cycle de vie ; revue après changement et périodique.	Rapprocher registre, terrain, cloud et inventaire existant ; justifier exclusions.	PR-11 : registre réconcilié et validé. Registre incomplet selon S2 ; V0 produite ici.	DSI / Production.
CT-12 21 §2 i	Comptes internes et tiers	Moindre privilège ; comptes nominatifs, séparation administration/usages, expiration des accès tiers et retrait après départ ; revue proposée trimestrielle.	Tester refus hors périmètre, compte expiré et retrait ; vérifier attribution des actions sur systèmes cibles.	PR-12 : matrice de droits, exports et revues. Accès tiers sans stratégie ni revue documentée.	DSI / Production ; RH pour mouvements, rôle proposé.
CT-13 21 §2 j	EA-05 vers EA-01	MFA avec au moins un facteur de connaissance (ReCyF 8.3-EE) sur accès VPN sensibles, exceptions identifiées et approuvées ; aucun accès tiers partagé ; prévoir moyens de communication de crise adaptés.	Tester connexion avec facteur, refus sans facteur/invalide, secours contrôlé et continuité ; ne pas supprimer accès avant solution validée.	PR-13 : paramètres et essais. VPN sans MFA établi par S2 ; communications de crise non décrites.	DSI, Production et RSSI.

6. Notification, supervision et contrôles associés

ID / base	Applicabilité / résultat attendu	Traduction technique et organisationnelle	Contrôle / preuve attendue	État et pilote
CT-14 Art. 23 §1–4	Hypothèse EE ; traiter les incidents significatifs selon critères du texte, pas tout événement technique.	PR-INC proposée : horodater prise de connaissance, qualifier gravité/impact, informer RSSI/direction, identifier CSIRT/autorité et canal national ; journal des décisions protégé.	PR-14 : chronologie, qualification, projet de notification et accusé de réception si envoi réel. Exercice étiqueté simulation ; aucun envoi externe effectué ici.	Procédure existante non documentée. RSSI pilote proposé, DSI/Production contributeurs.
CT-14a Art. 23 §4	Sans retard injustifié ; repères européens de notification.	Alerte précoce sous 24 h après prise de connaissance ; notification sous 72 h ; mises à jour et rapport intermédiaire sur demande ; rapport final au plus tard un mois après notification. Si incident en cours : rapport d’avancement puis final après traitement selon texte.	Exercice : T0 horodaté, échéances calculées, destinataires vérifiés et validation sans attendre l’enquête complète. Cas particuliers à vérifier ; aucun service de confiance décrit.	Aucun délai réellement mesuré. Articuler avec RGPD 33–34 si données personnelles ; circuits et critères distincts.
CT-15 Art. 31–32	Hypothèse EE ; coopération avec supervision et demandes légitimes.	Dépôt de preuve à accès contrôlé ; index source–contrôle–actif–preuve–date ; accès en lecture et journal des remises. Vérifier habilitation et périmètre de la demande.	PR-15 : index, habilitations, export anonymisé, bordereau de remise et suivi des mesures correctrices.	Dossier documentaire préparé ; aucun contrôle d’autorité attesté. RSSI/direction proposés.
JUR-01 Art. 3 §4, 26, 27–30	Art. 3 §4 : informations d’identification requises selon modalités nationales. Art. 26 : France ; 27–28 hors activité décrite ; 29–30 conditionnels.	Préparer identité, adresse, secteur et contacts ; vérifier transmission à l’autorité et mises à jour. Vérifier établissement et interlocuteurs. Si partage volontaire : accord, classification, destinataires et données minimales ; séparer du circuit obligatoire art. 23.	Décision juridique documentée ; accord de partage seulement si choisi. Aucune inscription à un registre réservé aux fournisseurs numériques déduite de l’usage du cloud.	Non évalué ; RSSI et appui juridique proposé.
JUR-02 Art. 34–35	Prendre en compte sanctions et articulation RGPD.	Pas de configuration directe. Intégrer risque de sanction à la gouvernance ; ne pas additionner mécaniquement sanctions pour un même comportement.	Analyse juridique au cas par cas. Art. 34 : maxima nationaux au moins 10 M€ ou 2 % pour EE, 7 M€ ou 1,4 % pour EI, montant supérieur retenu.	Aucune sanction ni violation juridique réelle établie ; droit national à vérifier.

7. Registre des actifs critiques — V0

Source S2, §2–5. Notes proposées de 1 faible à 4 critique. C = confidentialité ; I = intégrité ; D = disponibilité ; T = traçabilité. Globale = maximum(C,I,D,T). Les notes expriment les besoins métier, sans mesurer les protections existantes. D4 signifie besoin de continuité ; il ne prouve pas une disponibilité réelle de 100 %.

Actif / données	Responsable et dépendances connues	C/I/D/T → max	Justification des quatre notes / réserve
EA-01 SCADA États, mesures, commandes	Responsable Production ; GridSoft ; accès distant via EA-05.	3/4/4/4 → 4	C3 : équipes habilitées. I4 : commandes/états altérés affectent exploitation. D4 : continuité explicitement exigée. T4 : attribuer commandes et interventions. Impact détaillé à confirmer, sans approfondissement industriel.
EA-02 Compteurs Consommation, identifiant, adresse	Responsable métier à désigner ; Production proposée ; maintenance RéseauTech.	3/3/3/3 → 3	C3 : relevés rattachables aux clients. I3 : relevés erronés affectent usages SI. D3 : tolérance de relève jusqu'à 24 h proposée. T3 : accès et changements administratifs. Panne de relève ≠ coupure électrique.
EA-03 CRM/facturation Identité, adresse, IBAN, historique	DSI ; CloudPeak pour une partie de l'hébergement.	4/4/4/4 → 4	C4 : habilitations nominatives sur données clients/IBAN. I4 : contrats/factures altérés à grande échelle. D4 : continuité clientèle exigée. T4 : retracer accès et modifications. Droits et journaux réels non fournis.
EA-04 Analytics Consommation agrégée et individuelle	DSI ; hébergement CloudPeak.	3/4/3/3 → 4	C3 : données individuelles restreintes. I4 : prévisions erronées peuvent dégrader décisions de charge, hypothèse prudente. D3 : 24 h proposées. T3 : traitements et administration attribuables. Dépendance réelle des décisions à confirmer.
EA-05 VPN Identifiants et journaux de connexion	DSI ; techniciens et RéseauTech ; accès à EA-01.	4/4/3/4 → 4	C4 : secrets individuels. I4 : droits/configuration altérés ouvrent un accès indu. D3 : accès distant bloqué, 24 h proposées à confirmer. T4 : connexions et actions privilégiées. Les traces VPN seules ne prouvent pas les actions SCADA.

Échelle retenue : C1 public / C2 interne / C3 services habilités / C4 personnes explicitement autorisées ; I1 impact négligeable / I2 limité / I3 important / I4 majeur ; D1 >7 jours / D2 >24 h à 7 jours / D3 jusqu'à 24 h / D4 aucune interruption acceptable ; T1 aucun besoin particulier / T2 utilisateurs / T3 administrateurs en complément / T4 ensemble des actions.

Adaptation pédagogique : l'échelle d'intégrité du kit mélange fréquence de revue et impact ; les intervalles de disponibilité ont été explicités. À discuter au débrief. Compléter par instances, versions, emplacements, cycle de vie, date et validateur. Vérifier terrain (postes/disjoncteurs), identité, réseau, sauvegardes et collecte des traces : non décrits en détail, sans présumer leur absence. Le registre existant n'étant pas fourni, les actifs qui y manquent ne sont pas identifiables.

8. Registre des sous-traitants et prestataires

Ces relations sont décrites dans S2 §3–4. Le qualificatif « sous-traitant RGPD » et les rôles juridiques exacts restent à vérifier selon les traitements ; la gestion de la chaîne d'approvisionnement NIS2 ne se limite pas au RGPD.

ID / prestataire	Actifs / service	Situation connue et incertitudes	Exigences proposées / preuve attendue	Responsable interne
ST-01 GridSoft Solutions France	EA-01 ; éditeur et intégrateur SCADA.	Accès fourni à la demande, sans stratégie ni revue périodique documentée. Canal d'accès, droits, contrats, versions et engagements non fournis ; ne pas présumer un accès VPN GridSoft.	PR-ST-01/02 : mission, périmètre, interlocuteurs, engagements sécurité/incident/vulnérabilités ; PR-ST-03 : comptes autorisés et traçabilité ; PR-ST-04 : retrait. Preuves PR-06/12.	Responsable Production ; coordination DSI/RSSI proposée.
ST-02 CloudPeak Americas Filiale européenne d'un groupe américain	EA-03 partiel et EA-04 ; cloud public.	Aucun contrat mis en place et aucune analyse de risque documentée formalisée. Région, entité contractante, clés, sous-prestataires et réversibilité inconnus. Aucun transfert US ni accès étatique établi.	PR-ST-01/02 : analyse juridiction/contrôle/localisation, responsabilités partagées, accès, incident, sauvegarde, réversibilité ; clauses RGPD art. 28 et transferts si pertinents. Contrat et analyse approuvés, tests de sortie/restauration attendus.	DSI ; RSSI et juridique proposés pour risque/contrat.
ST-03 RéseauTech Maintenance France, PME régionale	EA-02 et équipements terrain ; accès VPN EA-05 vers supervision EA-01.	VPN sans MFA ; accès à la demande sans stratégie ni revue périodique documentée. Comptes, droits détaillés et durée d'accès inconnus.	PR-ST-03 : compte nominatif, MFA, droits limités à mission, expiration et fenêtre ; corréler connexions et interventions ; PR-ST-04 : retrait et preuve. Aucun secret à joindre au dossier.	Production pour terrain/supervision ; DSI pour VPN.

Tenue du registre proposée : identifiant stable, contrat et version, actifs/données accessibles, responsable interne, contacts d'incident, sous-prestataires, date d'évaluation, risque résiduel, prochaine revue et date de fin. Révision à chaque changement de mission, d'hébergement ou de droits ; revue périodique proposée trimestrielle pour les accès et annuelle pour le dossier fournisseur, à valider selon le risque.

9. Procédures proposées de gestion des tiers

Procédure / déclencheur	Responsable et déroulement proposé	Condition de contrôle / preuve
PR-ST-01 Avant sélection, renouvellement ou changement de périmètre	DSI ou Production recense service, données, actifs, accès et dépendances ; RSSI évalue criticité et risques, collecte engagements de sécurité et pratiques de traitement des vulnérabilités ; appui juridique examine juridiction et transferts éventuels.	Fiche fournisseur complète, risque motivé, questions ouvertes et décision approuvée. Refuser la clôture de l'évaluation si responsable, périmètre ou risque résiduel restent sans arbitrage.
PR-ST-02 Avant ouverture du service / régularisation cloud	Responsable interne formalise responsabilités partagées, droits d'audit proportionnés, incidents, vulnérabilités, continuité, réversibilité et sous-prestataires. Juridique proposé pour contrat et RGPD. RSSI examine garanties et écarts.	Contrat signé et annexes reliés à ST/EA ; décision documentée sur écarts. Situation CloudPeak à régulariser sans interruption non préparée. Une dérogation RSSI ne remplace pas un contrat ou une obligation légale.
PR-ST-03 Chaque demande d'accès et revue périodique	Demande identifie personne, mission, actifs, droits, début/fin et fenêtre. Responsable du système approuve ; DSI configure compte nominatif/MFA/droits/expiration. Production valide impact supervision. Contrôler traces utiles sans exposer de secrets. Revue trimestrielle proposée et après changement de mission.	Test connexion autorisée, refus hors périmètre et expiration ; export anonymisé, approbation, revue et décisions de retrait. Journal VPN à rapprocher des actions sur cible si disponibles. Exception de sécurité : RSSI seul, motif, mesures compensatoires et fin définie.
PR-ST-04 Fin de mission, incident ou fin de contrat	Responsable interne déclenche retrait ; DSI désactive comptes, sessions et accès, traite secrets partagés s'ils existent ; Production coordonne terrain. À la sortie : récupérer données/configurations selon contrat, vérifier reprise, puis effacement selon obligations de conservation. Incident : activer PR-INC et préserver traces.	Test d'accès refusé après retrait, inventaire des accès clos et données restituées, procès-verbal de sortie et attestation d'effacement si pertinente. Tester réversibilité avant dépendance définitive au fournisseur.

Statut des quatre procédures : rédigées comme propositions documentaires pour le scénario. Aucun contrat signé, compte créé/révoqué, contrôle d'expiration ni revue réellement exécutée n'est attesté. Approbation, diffusion, essai et preuve d'application restent nécessaires pour démontrer la mise en œuvre.

10. Plan d’action et index des preuves

Priorité / délai proposé	Écart ou point à vérifier	Action et pilote	Critère de clôture
P1 • J+7 étude	VPN sans MFA — CT-13	DSI et Production : compatibilité, scénario de secours et planification ; RSSI pour risques.	Essais avec/sans second facteur et continuité, preuve PR-13 ; déploiement seulement en fenêtre validée.
P1 • J+7 lancement	Cloud sans contrat/analyse — CT-02/06	DSI, RSSI, juridique proposé : analyse, responsabilités et engagements.	Analyse approuvée, décision de risque et contrat ; questions localisation/accès traitées.
P1 • J+15 première revue	Accès tiers sans revue — CT-12	DSI et Production : rapprocher missions/comptes, faire approuver puis retirer droits inutiles.	Revue datée, droits justifiés, expiration et tests de retrait.
P1 • J+30	Registre incomplet — CT-11	DSI et Production : comparer V0 à inventaire, terrain et cloud ; validation métier.	Actifs rapprochés, dépendances et cotations justifiées ; exclusions tracées.
P2 • J+30 vérification	Gouvernance, reprise, traces, notifications non documentées	RSSI, direction, DSI et Production : demander preuves existantes et planifier essais manquants.	Décision fondée sur preuves ou plan daté pour les lacunes ; aucune absence réelle déduite du silence du dossier.

Index : P-DOS-01 = dossier pédagogique ÉnergieAlp §1–6, producteur non nommé, date source non fournie ; lecture documentaire du 15/10/2026. Il établit les faits du scénario et leurs limites, sans attester une inspection réelle. DOC-01 = présent PDF et source Markdown ; DOC-02 = registre V0 du mémo ; DOC-03 = procédures PR-ST-01 à 04 incluses ici. Ce sont des productions documentaires disponibles.

PR-01 à PR-16 = emplacements logiques des futures preuves des contrôles portant le même numéro ; pas de pièces techniques collectées à ce stade. CT-06b partage PR-06. Les références non utilisées ne désignent aucune preuve existante.

Métadonnée requise pour chaque future preuve	Valeur à conserver
Identification et collecte	ID PR, contrôle CT, actif EA, fournisseur ST si pertinent ; producteur/collecteur nommé ; date, heure et fuseau ; période couverte.
Origine, méthode et résultat	Système/version, configuration effectivement chargée, comptes/échantillon ; export ou protocole de test ; attendu/constaté ; limites et conclusion.
Conservation et validation	Original dans espace contrôlé, version/empreinte si utile, droits et durée de conservation décidés ; copie anonymisée pour présentation ; relecteur et date.

11. Mise à jour : débrief et correspondance des matrices

V3 documentaire du 15 octobre 2026 : cadrage principal ReCyF et ajout des éléments de la séance de 3 h 30 en présentiel. La matrice et les contrôles initiaux sont conservés ; les compléments reprennent la nouvelle feuille du mémo. Aucun débrief, échange entre binômes, arbitrage ou adoption n’est présenté comme réalisé.

Ligne de la nouvelle feuille	Contrôle(s) du présent PDF	Objet
M-01	CT-13	MFA VPN
M-02	CT-02, CT-06 et CT-06b	Risques et garanties CloudPeak
M-03	CT-11	Registre des actifs
M-04	CT-12	Habilitations internes et tiers
M-05	CT-14 et CT-14a	Notification des incidents
M-06	CT-01	Gouvernance et politique
M-07	CT-02	Analyse des risques tous risques
M-08	CT-04 et CT-05	Continuité et crise
M-09	CT-07	Maintenance et vulnérabilités
M-10	CT-08 et CT-16	Efficacité et correction
M-11	CT-09 et CT-01	Formation et hygiène
M-12	CT-10	Cryptographie et clés
M-13	CT-02	Environnement physique : locaux, énergie et équipements
M-14	CT-03	Collecte, détection et traitement des incidents
M-15	CT-15	Dossier de supervision
M-16	JUR-01 et qualification section 1	Champ, identité, juridiction et modalités nationales

Points à arbitrer au débrief : adaptation de l’échelle C/I/D/T, maximum retenu, EA-04 I4 prudent, D3 provisoires et propriétaire EA-02. Conserver actif, ancienne/nouvelle note, motif, auteur, date et validateur. Aucune modification des notes n’est justifiée par une correction collective non reçue.

12. Cloud Act — conditions et risques concrets

Réutiliser les notions déjà travaillées dans le module Cloud/IAM et la comparaison d'un second fournisseur : responsabilités partagées, région, IAM, coût et réversibilité. Le laboratoire antérieur ne prouve aucune configuration de CloudPeak.

Faits : CloudPeak est une filiale européenne d'un groupe américain et héberge une partie du CRM ainsi que l'analytics. Aucun contrat ni analyse de risque formalisée n'est fourni. Le CRM traite notamment des IBAN ; l'analytics traite aussi des consommations individuelles. Localisation précise, accès d'administration, sous-prestataires et maîtrise des clés ne sont pas documentés.

Précision juridique : la formulation « société de droit américain » de la consigne est un point de départ simplifié. L'analyse doit examiner la juridiction américaine sur l'entité visée et la possession, garde ou maîtrise des données. Un stockage hors des États-Unis ne suffit pas à exclure une demande ; l'appartenance au groupe ne prouve ni qu'une demande a été émise ni que la maison mère peut obtenir toutes les données. DOJ — présentation du Cloud Act.

ID / actif	Scénario de risque à analyser	Information à obtenir	Mesure / preuve attendue
RC-01 / EA-03, EA-04	Demande légale adressée à une entité relevant de la juridiction américaine et pouvant produire les données	Entité contractante, structure du groupe, pouvoirs juridiques/techniques et procédure de demandes légales	Analyse juridique individualisée ; engagements d'information/contestation lorsque permis ; aucune garantie absolue déduite du contrat
RC-02 / EA-03	Divulgation de dossiers clients ou IBAN par un accès fournisseur, légal ou compromis	Administrateurs, lieux d'accès, habilitations, traces et sous-prestataires	Réduction des droits, traçabilité, chiffrement approprié et minimisation ; tests d'accès et matrice de responsabilités
RC-03 / EA-04	Réidentification ou usage indu de consommations prétendument agrégées	Granularité, possibilité de rattachement, finalités et jeux de données réellement nécessaires	Minimiser, pseudonymiser ou anonymiser si démontré ; vérifier les limites. Agrégation ne signifie pas anonymisation
RC-04 / EA-03, EA-04	Dépendance fournisseur et sortie impossible dans le délai métier	Formats/API, volumes, coûts de sortie, licences, services propriétaires, droits d'export	Export et restauration sur environnement cible ; estimation de durée et coût ; clause et test de réversibilité
RC-05 / EA-03, EA-04	Transfert hors EEE ou accès depuis un pays tiers sans garanties adaptées	Régions données/sauvegardes/support, destinataires, finalités et mécanisme juridique éventuel	Cartographie des flux et analyse RGPD selon réalité des transferts ; ne pas assimiler risque Cloud Act et transfert effectivement constaté

RC-01 à RC-05 : première identification destinée à la future matrice des risques fournisseurs. Probabilités et risques résiduels non chiffrés faute d'informations suffisantes. Aucun transfert vers les États-Unis ni demande d'accès effectif n'est établi.

13. Comparaison des offres cloud

Critère	Offre d’un hyperscaler américain : question à instruire	Offre revendiquant une souveraineté : question à instruire	Pièce de décision
SecNumCloud	L’offre précise possède-t-elle une qualification et pour quel périmètre ? Ne pas extrapoler depuis une autre offre ou une annonce	Vérifier offre, version, périmètre et validité ; une démarche « en cours » n’est pas une qualification acquise	Décision ANSSI et périmètre exact, vérifiés au choix du fournisseur
Siège et contrôle juridique	Entité contractante, groupe, juridictions et contrôle possible des données	Siège, actionnariat, contrôle, dépendances et sous-prestataires ; le siège français seul ne suffit pas	Analyse juridique documentée
Localisation et accès	Région de production, sauvegardes, support et administration	Mêmes vérifications, y compris support et services annexes	Carte des données et accès, engagements vérifiables
Sécurité et clés	Capacités IAM, traces, chiffrement, maîtrise du clair et responsabilités	Mêmes critères techniques ; vérifier mise en œuvre dans l’offre et dans le service client	Exports/tests sur périmètre pilote, sans présumer le résultat
Maturité et compatibilité	Compatibilité CRM/analytics, services propriétaires, support et compétences disponibles	Couverture fonctionnelle, dépendances, capacité et support effectifs	Pilote avec tests métier et techniques
Réversibilité	Exports complets, formats, documentation et frais de sortie	Même exigence ; changer de fournisseur ne supprime pas l’enfermement	Export/restauration réussis et délai mesuré
Coût global	Hébergement, licences, trafic, sortie, compétences et maintien des protections	Même périmètre, ajout migration, double exploitation et formation	Devis comparables ; aucun prix fictif
Continuité	Engagements de service, reprise, défaillance et secours	Mêmes exigences, validées sur offre et architecture réelles	Objectifs métier, contrat et test de reprise

SecNumCloud : vérifier qualification de l’offre exacte, périmètre et validité ; une démarche en cours ou un siège français ne suffit pas. La qualification de l’offre ne certifie pas automatiquement le CRM ni la configuration du client. Aucune obligation générale de migration SecNumCloud d’ÉnergieAlp n’est démontrée par le dossier.

Chiffrement : vérifier qui peut utiliser les clés et accéder au clair. Le chiffrement au repos géré par le fournisseur ne supprime pas à lui seul l’accès possible de celui-ci. Une clé dite client ne suffit pas si le service peut l’invoquer ; tester aussi récupération et contraintes fonctionnelles.

14. Orientation de maintien ou migration

Proposition : instruire une migration ciblée de la partie sensible du CRM, tout en préparant un maintien transitoire encadré pour préserver le service ; décider séparément pour l'analytics après examen des données individuelles et des garanties réelles. Ce choix est une orientation prudente fondée sur la sensibilité et les lacunes contractuelles, sans affirmer que CloudPeak est illégal par nature ou qu'un autre fournisseur éliminerait tout risque.

Étape	Travail / condition de passage	Responsable et preuve
1 — Contenir et clarifier	Recenser données et droits, demander éléments juridiques/techniques, lancer contractualisation ; éviter de nouveaux usages non évalués	DSI et RSSI, appui juridique proposé ; P-02 et décision tracée
2 — Évaluer le maintien	Maintien durable seulement si garanties juridiques/techniques suffisantes, contrat et risque résiduel examinés par les instances compétentes ; sinon déclencher scénario de sortie	Direction pour orientation/ressources ; RSSI pour dérogation de sécurité uniquement. Une tolérance interne ne légalise pas un traitement illicite
3 — Piloter une cible	Comparer au moins deux offres sur le même périmètre ; privilégier l'examen d'une offre qualifiée pour les données sensibles ; tester compatibilité, contrôle des clés, reprise et coût	DSI avec métiers et RSSI ; grille comparative, devis et tests. Aucun fournisseur sélectionné ici
4 — Décider par jeu de données	CRM : protéger données clients/IBAN ; analytics : déterminer si les données individuelles restent nécessaires et si les garanties permettent le maintien	Décision motivée par périmètre, conditions, risque résiduel, coût et date de réexamen
5 — Migrer si décidé	Sauvegarde et restauration préalables, synchronisation et intégrité vérifiées, bascule en fenêtre validée, critères de succès et retour arrière	DSI, validation métier ; CRM disponible selon contrainte du dossier. Maintien de l'ancienne instance seulement dans un périmètre approuvé
6 — Clore la sortie	Valider métier, retirer accès/sessions, récupérer données et configurations, traiter conservation/effacement selon obligations	Procès-verbal de recette, accès retirés, restitution et preuve d'effacement si applicable

Le maintien transitoire n'est ni approuvé ni exécuté ; il ne régularise pas l'absence de contrat. Une dérogation de sécurité RSSI ne légalise pas un traitement illicite. Si des faits révèlent une non-conformité juridique imposant une action immédiate, faire arbitrer sans attendre le calendrier indicatif.

15. Politique de sécurité simplifiée — rubriques 1 à 4

Politique V0 proposée pour revue croisée, non adoptée. Chaque règle indique résultat, périmètre, responsable et contrôle. Les références ReCyF sont indiquées sous chaque rubrique. Les références M renvoient à la correspondance section 11 ; les actions A-01 à A-06 et fréquences sont proposées, sous réserve d’approbation.

1 — Objet et périmètre

ReCyF : 1.1-EI/EE ; 1.2-EI/EE ; 1.3-EI/EE.

Protéger l’exploitation électrique, les services clients et les données sur EA-01 à EA-05 et leurs dépendances confirmées ; intégrer cloud et accès des prestataires. Direction approuve le périmètre proposé par DSI/Production avec RSSI. Contrôle : rapprochement annuel et après changement majeur entre politique, registre et matrice. Liens : M-03, M-06, M-16 ; A-04/A-06.

2 — Organisation de la sécurité

ReCyF : 2.A.1-EI/EE ; 2.A.2-EE ; 2.B.3-EI/EE.

Direction : approuver politique, moyens et arbitrages ; suivre les écarts et se former. RSSI : coordonner risques, incidents et contrôles ; valider seul les dérogations de sécurité, avec motif, périmètre, mesures compensatoires et date de fin. DSI : porter CRM, VPN et analytics ; Responsable Production : porter supervision ; propriétaire des compteurs à désigner. Utilisateurs : respecter habilitations et signaler les événements suspects. Contrôle : responsabilités nominatives, décisions et revue du suivi proposée trimestrielle. Liens : M-06/M-10 ; A-06.

3 — Gestion des actifs

ReCyF : 1.3-EI/EE ; 5.A.1-EI/EE ; 16.2-EE.

DSI/Production tiennent le registre avec identifiant, propriétaire, données, dépendances, criticité justifiée, version/support et emplacement ; ajout ou retrait déclenche une mise à jour. Toute cotation est validée par le métier concerné. Contrôle : rapprochement proposé trimestriel et après changement ; conserver historique et exclusions. Liens : EA-01 à EA-05 ; M-03/M-09 ; registre incomplet, A-04.

4 — Contrôle des accès

ReCyF : 8.3-EE ; 10.A.6-EI/EE ; 10.C.4-EI/EE ; 11.A.1-EI/EE ; 19.1-EE.

DSI, après accord du responsable du système, attribue des accès nominatifs limités au besoin ; applique aux accès VPN sensibles un MFA comprenant au moins un facteur de connaissance, après essais, sépare administration/usages et retire les droits en fin de mission. Les accès tiers ont une date de fin et une revue proposée trimestrielle. Contrôle : approbations, tests autorisé/refusé, expiration et retrait ; exceptions bornées validées par RSSI. Liens : M-01/M-04 ; VPN sans MFA et revues absentes, A-01/A-03.

15 bis. Politique de sécurité simplifiée — rubriques 5 et 6

5 — Sécurité physique des sites et équipements

ReCyF : 6.1-EI/EE ; 6.3-EE ; 6.4-EI/EE.

Production pour supervision/terrain et DSI pour locaux SI, rôles proposés à confirmer, réservent l’accès physique aux personnes habilitées ; définissent accueil des visiteurs, protection des équipements et mesures face aux pertes d’énergie et risques environnementaux. Contrôle : liste des zones et droits, revue proposée trimestrielle et contrôle d’un scénario autorisé. Liens : M-07/M-13 ; contrôles non documentés, A-04.

6 — Gestion des incidents

ReCyF : 12.1-EE ; 12.3-EI/EE ; 12.5-EE ; 20.1-EE.

Utilisateurs et prestataires signalent rapidement les événements au contact interne désigné ; DSI/Production préservent les traces, qualifient avec RSSI et appliquent l’escalade. Le RSSI organise les notifications requises avec la direction et les rôles formalisés, selon critères et délais de l’article 23 et modalités nationales vérifiées. Contrôle : procédure, annuaire, chronologie et exercice proposé semestriel ; distinguer incidents significatifs, autres événements et violation de données personnelles. Liens : M-05/M-14 ; procédure non décrite, A-05.

16. Politique de sécurité simplifiée — rubriques 7 à 9

7 — Continuité et reprise d’activité

ReCyF : 13.2-EI/EE ; 13.4-EE ; 13.6-EE ; 14.2-EI/EE ; 14.10-EE.

DSI/Production avec les métiers définissent les objectifs de reprise et perte admissible par actif, organisent sauvegardes, restauration et modes dégradés ; planifient les changements selon les fenêtres du dossier. Toute modification prévoit tests et retour arrière. Contrôle : restauration isolée proposée semestrielle et après changement majeur, mesures comparées aux objectifs approuvés, exercice de crise. Liens : EA-01/EA-03 prioritaires ; M-08 ; reprise non documentée, A-05.

8 — Gestion des sous-traitants

ReCyF : 3.A.1-EI/EE ; 3.B.1-EI/EE ; 3.B.2-EI/EE ; 16.2-EE.

Responsable interne du service, avec RSSI et appui juridique proposé, évalue le fournisseur avant engagement ou changement ; formalise accès, sécurité, incidents, sous-prestataires, continuité et sortie dans les engagements appropriés. Relier GridSoft, CloudPeak et RéseauTech aux actifs et aux risques RC-01 à RC-05, puis à la future matrice des risques fournisseurs. Contrôle : dossier fournisseur proposé annuel, revue des accès trimestrielle et après changement ; PR-ST-01 à PR-ST-04 ci-dessous. Liens : M-02/M-04/M-09 ; contrat et analyse cloud absents, A-02/A-03.

9 — Sensibilisation et formation du personnel

ReCyF : 4.1-EI/EE ; 4.2-EI/EE ; 4.4-EI/EE ; 4.5-EI/EE.

RSSI, avec RH proposée et responsables opérationnels, organise accueil sécurité avant accès, rappel annuel et formation adaptée aux administrateurs, utilisateurs, direction et tiers selon leur mission. Inclure signalement d’incident, accès distant et protection des données. Contrôle : programme, participation et évaluation ; formation complémentaire selon difficultés observées. Liens : M-11 ; formation non documentée, A-06.

16 bis. Politique de sécurité simplifiée — rubriques 10 et 11

10 — Conformité et audit

ReCyF : 2.C.1-EI/EE ; 2.C.2-EI/EE ; 17.1-EE ; 18.3-EE ; 20.5-EE.

RSSI avec appui juridique proposé tient la matrice d’applicabilité et les sources à jour ; DSI/Production fournissent les preuves des contrôles, corrigent les écarts et testent l’efficacité avant clôture. Réduire exposition et vulnérabilités selon le risque, maîtriser chiffrement et clés ; coopérer aux demandes habilitées des autorités. Conserver les données de supervision au moins trois mois selon 20.5-EE, sous réserve des autres obligations, et tracer la différence de formulation du délai 20.1-EE. Contrôle : revue proposée trimestrielle du plan et annuelle de la matrice, contrôle après incident/changement majeur ; aucune conformité déclarée sans preuve. Liens : M-09/M-10/M-12/M-15/M-16 ; A-06.

11 — Revue et mise à jour de la politique

ReCyF : 1.3-EI/EE ; 2.B.3-EI/EE ; 16.4-EE.

RSSI propose une révision annuelle et après incident significatif, changement fournisseur/architecture ou évolution juridique ; direction approuve, les responsables diffusent et organisent l’application. Contrôle : version, auteur, date, motifs, approbation et diffusion ; dérogations revues à leur échéance. La V0 reste conservée pour retracer les choix. Liens : M-06/M-10/M-16 ; A-06.

Concordance du plan de la feuille : A-01 = MFA ; A-02 = cloud et clés ; A-03 = revue des accès ; A-04 = inventaire, risques et physique ; A-05 = incidents, traces et reprise ; A-06 = gouvernance, contrôles, formation et cadre juridique. Le plan de la section 10 couvre ces axes ; les échéances ne sont pas des délais légaux.

Les procédures PR-ST-01 à PR-ST-04 de la section 9 complètent la rubrique 8 : évaluation, contractualisation, accès/revue, incident/sortie. Les preuves de signature, revue et retrait restent à recueillir.

17. Revue croisée et état des nouvelles productions

Grille proposée pour échanger avec un autre binôme puis débriefer avec le formateur. Aucun commentaire ni validation ne leur est attribué. Conserver la version initiale, les commentaires reçus avec auteur/date, les corrections et la décision après réalisation.

Contrôle de relecture	Point précis à vérifier	Preuve / décision à consigner après échange
Criticité	Notes EA-04 I4 et D3 provisoires ; justification par dimension, propriétaire EA-02	Auteur, actif, ancienne/nouvelle note, motif et validateur
Applicabilité	Hypothèse EE, exclusions article par article, source européenne versus droit national	Article, fait, réserve levée ou vérification à poursuivre
Traçabilité	Chaque rubrique de politique renvoie à un actif, une ligne M, un écart ou une action	Rubrique, référence manquante éventuelle et correction
Contrôle des règles	Résultat attendu, responsable, périmètre et preuve vérifiable	Test proposé, critère de réussite et responsable de collecte
Cloud Act	Juridiction et contrôle réel, distinction risque/transfert, clés et usage du clair	Question au fournisseur, pièce attendue et effet sur la décision
Faisabilité	Fenêtres, continuité, coût, compatibilité et retour arrière	Condition de mise en œuvre, arbitrage et délai
Adoption	La politique est-elle approuvée, diffusée et appliquée ?	À ce stade : non documenté ; ne pas confondre rédaction et adoption

Disponible : analyse RC-01 à RC-05, grille de comparaison, orientation conditionnelle, politique V0 en onze rubriques et grille de revue. À recueillir : réponses fournisseur, offres et devis, analyse juridique individualisée, arbitrage direction, retours de binôme, approbation et preuves d’application.

Origine des compléments : docs/droit-conformite/it-2/debrief-matrice-cloud-act-politique-securite.md. Les renvois au module Cloud/IAM mobilisent des acquis ; ils ne prouvent aucune configuration de CloudPeak.

18. Bilan de preuve et références

Critère du formateur	Travail produit	Éléments restant à démontrer
Matrice ReCyF et correspondance NIS2	Vingt objectifs ReCyF et MAC sélectionnés structurent le contrôle ; quarante-six articles NIS2 examinés en annexe. Configuration, preuve et action par objectif.	Qualification confirmée sur périmètre juridique ; vérification du droit français et des modalités applicables.
Lien obligations / configurations	CT-01 à CT-16 et CT-06b ; objectifs, paramètres cibles, tests et références de preuve.	Exports réels, tests datés, comportement constaté et traitement des écarts ; aucune efficacité opérationnelle démontrée.
Registre des actifs critiques	Cinq services identifiés, responsables connus ou proposés, dépendances, C/I/D/T justifiés et réserves.	Inventaire existant réconcilié, instances/versions/sites, actifs de support et validation métier.
Politique et décision cloud	Analyse de risques cloud, comparaison et orientation ; politique V0 en onze rubriques.	Retours de revue croisée, arbitrage direction, approbation, diffusion et application.
Gestion des sous-traitants	Trois prestataires recensés et quatre procédures : qualification, contractualisation, accès/revue, incident/sortie.	Approbation, contrats, évaluations, revues et preuves d'application.

Conclusion de portée : ce livrable étaye la participation à l'élaboration de la politique de sécurité par un travail de qualification, de formalisation et de préparation des contrôles. Il ne suffit pas à démontrer leur mise en œuvre. Aucune conformité globale, certification, approbation du formateur ou exécution réelle n'est revendiquée.

Références consultées le 15 octobre 2026 ; reformulations pédagogiques, sans reproduction extensive du texte légal :

ReCyF — référentiel principal de l'exercice : https://messervices.cyber.gouv.fr/documents-ressources/20260317_NIS_V2_ReCyF_v2.5.pdf

S1 — Directive (UE) 2022/2555, articles 1–46 et annexe I : https://eur-lex.europa.eu/eli/dir/2022/2555/oj

S4 — ANSSI, directive NIS2 : https://cyber.gouv.fr/reglementation/cybersecurite-systemes-dinformation/directives-nis-nis2-et-dispositif-saiv/directive-nis-2/

Orientation de qualification : https://messervices.cyber.gouv.fr/conseils-cyber/directive-nis2-mon-organisation-est-elle-concernee

RGPD (articulation cloud et incidents) : https://www.cnil.fr/fr/reglement-europeen-protection-donnees

S2 — Source locale : docs/droit-conformite/annexes/dossier-entreprise-energiealp.md, §1 à §6.

S3 — Analyse initiale : docs/droit-conformite/it-1/de-exigence-a-preuve.md et comprendre-conformite-reglementaire.md ; registre : docs/droit-conformite/it-2/registre-actifs-critiques.md.

Pour le débrief : confirmer les décisions d'applicabilité, les cotations provisoires (notamment EA-04 I4 et les D3), les pilotes et les échéances ; identifier les preuves opérationnelles attendues avant d'attribuer un état de conformité.

Annexe juridique NIS2 — articles 1 à 16

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

Art.	Objet résumé	Code	Lien au périmètre / décision motivée
1	Objet	H	Cadre de la directive ; aucun réglage technique isolé à en déduire.
2	Champ	A	Électricité et taille : qualification ci-dessus ; confirmer le périmètre.
3	EE / EI	A	EE proposée ; supervision art. 32 et informations d’identification art. 3 §4 à préparer selon modalités nationales. Pas de décision officielle.
4	Textes sectoriels UE	C	Rechercher équivalence sectorielle au sens du texte ; aucune exclusion établie dans le dossier.
5	Harmonisation minimale	H	Cadre pour les États ; vérifier exigences françaises additionnelles.
6	Définitions	H	Fixer vocabulaire incident, risque, entité et systèmes dans les procédures.
7	Stratégie nationale	H	Responsabilité étatique ; pas de stratégie nationale à produire par ÉnergieAlp.
8	Autorités / points de contact	H	Identifier les interlocuteurs officiels dans PR-INC ; ÉnergieAlp ne les désigne pas.
9	Gestion nationale des crises	H	Articuler l’escalade interne avec les autorités ; dispositif national hors maîtrise interne.
10	CSIRT nationaux	H	Référencer le CSIRT compétent, sans assimiler l’équipe interne à un CSIRT national.
11	Capacités / missions CSIRT	H	Obligations des CSIRT ; prévoir coopération et éléments d’incident côté entité.
12	Divulgation coordonnée	C	Prévoir réception et transmission des vulnérabilités ; mécanisme national hors entité.
13	Coopération nationale	H	Organisation des autorités ; tenir des contacts internes cohérents.
14	Groupe de coopération	H	Structure européenne ; pas de configuration ÉnergieAlp directement exigée.
15	Réseau des CSIRT	H	Coopération européenne ; contribution via le CSIRT compétent si nécessaire.
16	EU-CyCLONe	H	Coordination des crises majeures ; conserver chaîne d’escalade interne.

Annexe juridique NIS2 — articles 17 à 31

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

Art.	Objet résumé	Code	Lien au périmètre / décision motivée
17	Coopération internationale	H	Cadre institutionnel ; pas d’obligation technique autonome identifiée.
18	Rapport européen	H	Rapport sur l’état de la cybersécurité ; exploiter comme contexte de risque.
19	Évaluation par les pairs	H	Mécanisme institutionnel ; ne pas le confondre avec audit interne.
20	Gouvernance	A	CT-01 : politique approuvée, suivi et formation de la direction.
21	Gestion des risques	A	CT-02 à CT-13 ; décomposition §2 a à j, proportionnalité et fournisseurs.
22	Chaînes critiques	H	Évaluations coordonnées au niveau UE ; intégrer leurs résultats disponibles dans CT-06.
23	Notifications	A	CT-14 : qualification, horodatage, destinataires et délais de notification.
24	Certification	C	Rechercher une exigence imposée au périmètre concerné ; aucun certificat exigé démontré ici.
25	Normalisation	H	Utiliser les normes pertinentes comme moyens ; aucune obligation générale ISO 27001 déduite.
26	Juridiction / territorialité	A	France pour l’entité décrite ; confirmer établissement et autorités. Cloud : analyser séparément le fournisseur.
27	Registre de certaines entités	X	Activités numériques listées non décrites pour ÉnergieAlp ; utiliser un cloud ne fait pas d’elle un fournisseur cloud.
28	Données d’enregistrement DNS	X	Aucun service de registre de domaine ou d’enregistrement visé décrit.
29	Partage d’informations	C	Participation éventuelle à encadrer ; pas d’adhésion ni d’accord existant prouvé.
30	Notification volontaire	C	Circuit distinct des notifications obligatoires ; préciser les cas dans PR-INC.
31	Supervision générale	A	Préparer dossier de preuve et coopération ; encadre surtout les pouvoirs des autorités.

Annexe juridique NIS2 — articles 32 à 46

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

Art.	Objet résumé	Code	Lien au périmètre / décision motivée
32	Supervision EE	A	CT-15 : produire preuves et suivre demandes d’audit dans l’hypothèse EE.
33	Supervision EI	X	Non retenu avec hypothèse EE ; réexaminer si qualification modifiée.
34	Amendes administratives	A	Prendre en compte gouvernance et risque juridique ; pas d’amende effective déduite du dossier.
35	Articulation RGPD	C	Articuler incident cyber et violation personnelle ; ne pas confondre notifications NIS2/RGPD.
36	Sanctions nationales	H	Règles à établir par les États ; vérifier droit national avant chiffrage opérationnel.
37	Assistance mutuelle	H	Coopération entre autorités ; centraliser réponses et demandes côté entité.
38	Délégation	H	Pouvoirs de la Commission ; aucune configuration directement applicable.
39	Comité	H	Procédure institutionnelle ; aucune action technique interne autonome.
40	Réexamen	H	Suivre évolution du texte dans la veille juridique.
41	Transposition	H	Vérifier les textes nationaux et leurs dates ; la directive seule ne décrit pas toutes les modalités françaises.
42	Modification UE 910/2014	H	Articulation des textes ; pas de service de confiance décrit pour ÉnergieAlp.
43	Modification UE 2018/1972	H	Articulation communications électroniques ; aucune activité de fournisseur décrite.
44	Abrogation NIS1	H	Distinguer ancien statut OSE et qualification EE/EI ; ne pas les confondre.
45	Entrée en vigueur	H	Repère temporel européen ; ne vaut pas preuve de mise en œuvre nationale.
46	Destinataires	H	Directive adressée aux États membres ; exigences opérationnelles à lire avec transposition.